Chapter 4: Introduction to Database Security

Chapter 7: Introduction to database security

7.1 Introduction

A database represents an essential corporate resource that should be properly secured using appropriate controls. In this section we describe the scope of database security and discuss why organizations must take seriously potential threats to their computer systems. We also identify the range of threats and their consequences on computer systems. In addition, we shall also discuss the mechanisms that protect the database against intentional or accidental threats.

In context of database systems, security considerations apply to not just the data held in a database but also other parts of the system, which may in turn affect the database such as hardware, software, people, and data. To effectively implement security requires appropriate controls, which are defined in specific mission objectives for the system.

7.2 Database security situations

We shall consider database security in relation to the following situations: *theft and fraud, loss of confidentiality (secrecy), loss of privacy, loss of integrity and loss of availability.*

These situations broadly represent areas in which the organization should seek to reduce risk, that is, the possibility of incurring loss or damage. In some situations, these areas are closely related such that an activity that leads to loss in one area may also lead to loss in another.

7.1 Theft and Fraud

This doesn't only affect the database environment but also the entire organization. It doesn't necessarily alter data, as is the case for activities that result in either loss of confidentiality or loss of privacy.

7.2 Confidentiality

This refers to the need to maintain secrecy over data. Breaches of security resulting in loss of confidentiality could, for instance, lead to loss of competitiveness, and

7.3 Privacy

This refers to the need to protect data about individuals. loss of privacy could lead to legal action being taken against the organization.

7.4 Loss of integrity

Loss of data integrity results in invalid or corrupted data, which may seriously affect the operation of an organization.

7.5 Loss of availability

This means that the data, or the system, or both cannot be accessed, which can seriously affect an organization's performance. In some cases, events that cause a system to be unavailable may also cause data corruption.

7.6 Database Threats

This refers to any situation or event, whether intentional or accidental, that may adversely affect a system and consequently the organization. Threats may be caused by a situation/event involving a person, action, or circumstance that is likely to bring harm to an organization.

The harm may be tangible, such as loss of hardware, software, or data, or intangible, such as loss of credibility or client confidence. The biggest challenge facing most organization is to identify all possible threats.

Areas of loss may result from intentional or unintentional activities. However, the impact remains the same.

Intentional threats involve people and may be perpetrated by both authorized users and unauthorized users, some of whom may be external to the organization.

7.7 Example of Database Threats

Some examples of database threats includes ***using another person's means of access, unauthorized amendment or copying of data, program or data alteration, inadequate policies and procedures that allow a mix of confidential and normal output, wiretapping, illegal entry by an hacker, creating trap doors into the system, wiretapping, black mail, Creating "trapdoor" into system, Theft of data, programs, and equipment, Failure of security mechanisms, giving greater access than normal, Staff shortages or strikes, Inadequate staff training, Viewing and disclosing unauthorized data, Electronic interference and radiation, Data corruption owing to power loss or surge, Fire (electrical fault, lightning strike, arson), flood, bomb, Physical*** damage to

equipment, Breaking cables or disconnection of cables, Introduction of viruses

NB: Students to do more personal research to identify how the above threats can occur in a database system

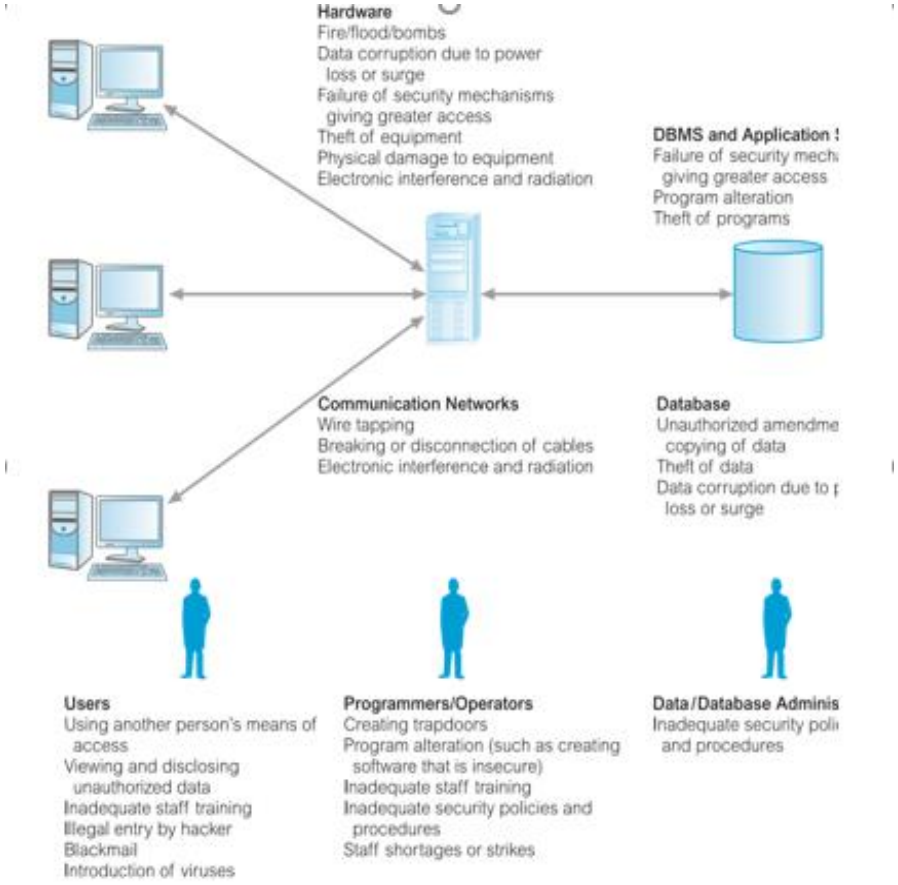

Fig 7.0- Summary of database threats

7.8 Countermeasures—Computer-based Controls

Ccountermeasures range from physical controls to administrative procedures. Despite the range of computer-based controls that are available, it is worth noting that generally, the security of a DBMS is only as good as that of the operating system, owing to their close association.

In this section, we shall we focus on the following computer-based security controls for a multi-user environment (some of which may not be available in the PC environment): *authorization (1), access controls (2), views (3), backup and recovery (4), integrity(5), encryption (6) and RAID technology.*

7.8.1 Authorization

This means granting of a right or privilege that enables a subject to have legitimate access to a system or a system's object. Authorization controls can be built into the software and govern not only what system or object a specified user can access, but also what the user may do with it.

Aauthorization process involves authentication of subjects requesting access to objects, where "subject" represents a user or program and "object" represents a database table, view, procedure, trigger, or any other object that can be created within the system.

Authentication is a mechanism that determines whether a user is who he or she claims to be.

7.8.2 Access Controls

The typical way to provide access controls for a database system is based on the granting and revoking of privileges. A **privilege** allows a user to create or access (that is read, write, or modify) some database object (such as a relation, view, or index) or to run certain DBMS utilities. Privileges are granted to users to accomplish the tasks required for their jobs. There are two types of Access controls i.e. *discretionary Access Control (DAC) and Mandatory Access Control*

7.8.3 Views

A view is the dynamic result of one or more relational operations operating on the base relations to produce another relation. A view is a *virtual relation* that does not actually exist in the database, but is produced upon request by a particular user, at the time of request.

The view mechanism provides a powerful and flexible security mechanism by hiding parts of the database from certain users. The user is not aware of the existence of any attributes or rows that are missing from the view. A view can be defined over several relations with a user being granted the appropriate privilege to use it, but not to use the base relations. In this way, using a view is more restrictive than simply having certain privileges granted to a user on the base relation(s). We discussed views in detail in chapter 6

7.8.4 Backup and Recovery

This refers to the process of periodically copying of the database and log file (and possibly programs) to offline storage media.

A DBMS should provide backup facilities to assist with the recovery of a database following failure. It is always advisable to make backup copies of the database and log file at regular intervals and to ensure that the copies are in a secure location. In the event of a failure that renders the database unusable, the

backup copy and the details captured in the log file are used to restore the database to the latest possible consistent state.

7.8.5 Integrity

Integrity constraints also contribute to maintaining a secure database system by preventing data from becoming invalid, and hence giving misleading or incorrect results. Integrity constraints were discussed in detail in chapter 3

7.8.6 Encryption

The encoding of the data by a special algorithm that renders the data unreadable by any program without the decryption key.

If a database system holds particularly sensitive data, it may be deemed necessary to encode it as a precaution against possible external threats or attempts to access it. Some DBMSs provide an encryption facility for this purpose. The DBMS can access the data (after decoding it), although there is a degradation in performance because of the time taken to decode it. Encryption also protects data transmitted over communication lines.

7.8.7 RAID (Redundant Array of Independent Disks)

The hardware that the DBMS is running on must be fault-tolerant, meaning that the DBMS should continue to operate even if one of the hardware components fails. This suggests having redundant components that can be seamlessly integrated into the working system whenever there is one or more component failures. The main hardware components that should be fault-tolerant include disk drives, disk controllers, CPU, power supplies, and cooling fans. Disk drives are the most vulnerable components, with the shortest times between failure of any of the hardware components.

One solution is the use of Redundant Array of Independent Disks (RAID) technology. RAID originally stood for Redundant Array of Inexpensive Disks, but more recently the “I” in RAID has come to stand for Independent. RAID works on having a large disk array comprising an arrangement of several independent disks that are organized to improve reliability and at the same time increase performance.